Tự dựng web app cùng Codex

Cẩm nang cho người mới, dùng Windows

Bản 04/11/2026

Bộ khung ai-app-starter · Codex · Claude Code · React · Supabase · Cloudflare

Mục lục

Bộ khung này giúp gì 3

Cần gì, tốn bao nhiêu 3

Cài công cụ trên Windows 4

Cài Codex: chọn một trong ba cách 4

Tạo dự án và bắt đầu với agent 5

Tạo dự án từ template 5

Mở bằng Codex và bật lớp bảo vệ 5

Câu đầu tiên và cách trả lời agent 5

Mỗi mốc diễn ra thế nào 6

Quyền của agent: khi nào phải dừng đọc kỹ 6

Giới hạn miễn phí và mốc trả tiền 7

Hai sự cố có thật và cách bộ khung chặn 8

Lovable và RLS bị thiếu (2025) 8

Replit xoá database thật (07/2025) 9

Sự cố hay gặp và cách gỡ 9

Supabase báo project bị tạm dừng 9

Hết hạn mức Codex 9

Lỗi build 10

Agent đi lạc, muốn quay lại bản trước 10

Sao lưu và thử phục hồi database 10

Lỡ để lộ key 10

Thuật ngữ 11

Nguồn 11

Bộ khung này giúp gì

Bạn có ý tưởng một app nhỏ: sổ chi tiêu, trang đặt lịch, danh sách việc cho nhóm. Bạn biết chút code nhưng chưa từng tự dựng một app có đăng nhập, có database, có link để gửi cho người khác. Codex (trợ lý lập trình của OpenAI) có thể viết phần lớn code đó, nhưng nếu chỉ nói "làm cho mình app X", nó thường đoán ý, chọn công nghệ lung tung, và có lúc chạy những lệnh nguy hiểm như xoá thư mục hay xoá database.

Bộ khung `ai-app-starter` là một repo mẫu trên GitHub. Repo không có sẵn app nào. Nó chứa một bộ luật cho agent (file `AGENTS.md`), vài mẫu tài liệu trống, một lớp chặn lệnh nguy hiểm, và script sao lưu database. Khi bạn mở dự án bằng Codex và kể ý tưởng, agent sẽ đi theo một luồng cố định: hỏi bạn vài câu có gợi ý sẵn, đề xuất giải pháp kèm chi phí, chờ bạn đồng ý, chia việc thành mốc nhỏ, rồi làm từng mốc. Mốc nào xong cũng chạy được và mở ra xem được, và agent ghi lại tiến độ để hôm sau làm tiếp.

Cẩm nang này đi theo đúng thứ tự bạn sẽ làm: chuẩn bị tài khoản và chi phí, cài công cụ trên Windows, tạo dự án, làm việc với agent, hiểu khi nào phải dừng lại đọc kỹ, các giới hạn miễn phí, hai sự cố bảo mật có thật để biết vì sao bộ khung chặt như vậy, và cách gỡ các lỗi hay gặp. Số liệu giá trong tài liệu được kiểm ngày 04/11/2026, kèm link nguồn; giá đổi thường xuyên nên trước khi trả tiền hãy mở lại trang nguồn.

Cần gì, tốn bao nhiêu

Bạn cần bốn tài khoản. Chỉ tài khoản đầu tiên tốn tiền ngay từ đầu.

Tài khoản	Dùng để	Chi phí khởi đầu
ChatGPT Plus	Dùng Codex trong app, VS Code và terminal	$20/tháng
GitHub	Lưu code, tạo dự án từ template	Miễn phí
Supabase	Database, đăng nhập, lưu file nhỏ	Miễn phí (gói Free)
Cloudflare	Đưa app lên mạng (Cloudflare Pages)	Miễn phí

Về Codex: gói Free và Go ($8/tháng) của ChatGPT cũng có Codex, nhưng theo trang giá chỉ dùng được model nhỏ trong app máy tính. Gói Plus ($20/tháng) dùng được Codex trên web, trong terminal (CLI), trong extension VS Code, với các model mạnh hơn. Mỗi gói có hạn mức dùng tính theo khung 5 giờ và theo tuần; hết hạn mức thì chờ tới lúc reset hoặc mua thêm credit. Nguồn: https://learn.chatgpt.com/docs/pricing. Trang giá ghi mức giá hiện tại áp dụng ít nhất tới 21/11/2026, nên sau ngày đó hãy xem lại.

Phương án thay thế là Claude Pro của Anthropic, $20/tháng (hoặc $17/tháng nếu trả theo năm), có kèm Claude Code. Bộ khung chạy được với Claude Code vì file `CLAUDE.md` chỉ trỏ sang `AGENTS.md`. Nguồn: https://claude.com/pricing.

Chi phí sau này chỉ phát sinh khi app lớn lên: nhiều dữ liệu, nhiều người dùng, cần backup tự động, hay lưu file lớn. Bảng ở chương "Giới hạn miễn phí và mốc trả tiền" ghi cụ thể từng mốc. Với một app cá nhân hay nhóm nhỏ, thường bạn chỉ trả $20/tháng cho ChatGPT Plus.

Cài công cụ trên Windows

Cần Windows 11 (khuyến nghị) hoặc Windows 10 bản mới. Theo tài liệu Codex, Windows 11 là nền được hỗ trợ chính, Windows 10 chỉ ở mức "cố gắng hỗ trợ". Bạn không cần WSL (Linux chạy trong Windows): Codex hiện chạy thẳng trên Windows bằng PowerShell và sandbox riêng của Windows. Chỉ dùng WSL2 khi dự án cần công cụ chỉ có trên Linux. Nguồn: https://learn.chatgpt.com/docs/windows/windows-sandbox.

Cách cài nhanh nhất là dùng `winget`, trình cài phần mềm có sẵn trong Windows. Mở **PowerShell** (bấm phím Windows, gõ "PowerShell", Enter) rồi dán từng dòng:

```
winget install --id Git.Git
winget install --id OpenJS.NodeJS.LTS
winget install --id Microsoft.VisualStudioCode
winget install --id GitHub.cli
```

Mỗi lệnh có thể hỏi đồng ý điều khoản, gõ `Y` rồi Enter. Cài xong **đóng PowerShell và mở lại** để Windows nhận các lệnh mới, rồi kiểm:

```
git --version
node --version
gh --version
```

Mỗi dòng in ra số phiên bản là được. Lệnh `node` phải ra bản 20 trở lên.

Git lưu lịch sử thay đổi của code, giúp quay lại bản trước khi agent làm hỏng. **Node.js** chạy các công cụ JavaScript; app React và script của bộ khung đều cần nó. **VS Code** là trình soạn code. **GitHub CLI** (`gh`) giúp đăng nhập GitHub từ terminal; chạy `gh auth login` một lần và làm theo hướng dẫn trên màn hình (chọn GitHub.com, HTTPS, đăng nhập bằng trình duyệt).

Nếu PowerShell báo lỗi kiểu `npm.ps1 cannot be loaded because running scripts is disabled on this system`, tài liệu Codex gợi ý chạy `Set-ExecutionPolicy -ExecutionPolicy RemoteSigned` cho tài khoản của bạn. Đọc giải thích của Microsoft trước khi đổi: https://learn.microsoft.com/powershell/module/microsoft.powershell.core/about/about_execution_policies.

Cài Codex: chọn một trong ba cách

Codex có ba cách dùng trên Windows, đều đăng nhập bằng tài khoản ChatGPT:

1. **App ChatGPT cho máy tính** (Microsoft Store). Giao diện dễ nhất, có khung xem thay đổi, terminal tích hợp. Cài bằng Store hoặc lệnh `winget install --id 9PLM9XGG6VKS -s msstore`. Nguồn: https://learn.chatgpt.com/docs/windows/windows-app.
2. **Extension trong VS Code**: mở VS Code, bấm biểu tượng Extensions (bốn ô vuông) ở cột trái, tìm `openai.chatgpt` (tên hiển thị có chữ Codex của OpenAI), bấm Install, rồi đăng nhập. Hợp nếu bạn muốn xem code và nói chuyện với agent trong cùng một cửa sổ. Nếu extension đứng im không chạy, tài liệu Codex gợi ý cài Visual C++ Redistributable hoặc Visual Studio Build Tools. Nguồn: https://learn.chatgpt.com/docs/ide.

3. **Codex CLI** trong terminal: `npm install -g @openai/codex`, rồi gõ `codex` và chọn đăng nhập bằng ChatGPT. Nguồn: https://github.com/openai/codex.

Lời khuyên: dùng app hoặc extension cho việc hằng ngày, và cài thêm CLI vì có một bước duyệt hook (lớp chặn lệnh) mà tài liệu chỉ mô tả cho CLI, ở chương sau.

Docker Desktop chưa cần ngay. Bạn chỉ cần nó khi bắt đầu sao lưu database (chương cuối). Lúc đó tải ở https://www.docker.com/products/docker-desktop/.

Tạo dự án và bắt đầu với agent

Tạo dự án từ template

1. Mở trang repo `ai-app-starter` trên GitHub, bấm nút xanh **Use this template** > **Create a new repository**.
2. Đặt tên dự án bằng chữ thường tiếng Anh, ví dụ `expense-tracker`. Chọn **Private** nếu chưa muốn ai thấy code.
3. Bấm **Create repository**. Bạn có một repo mới với đủ file của bộ khung.
4. Lấy code về máy: trong VS Code bấm **Clone Git Repository**, dán link repo mới, chọn một thư mục như `C:\Users\<tên>\projects`. Tránh để dự án trong OneDrive vì đồng bộ có thể khoá file khi agent đang ghi.

Mở bằng Codex và bật lớp bảo vệ

Mở **thư mục gốc** của dự án (thư mục có file `AGENTS.md`) bằng app ChatGPT, VS Code, hoặc gõ `codex` trong terminal đã `cd` vào thư mục đó. Mở đúng gốc là quan trọng: lớp chặn lệnh tìm file theo thư mục bạn mở.

Lần đầu, Codex hỏi bạn có tin (trust) thư mục này không. Chọn **trust**. Codex chỉ đọc cấu hình riêng của dự án (thư mục `.codex/`) khi bạn đã trust; không trust thì nó bỏ qua cả lớp chặn lệnh. Nguồn: https://learn.chatgpt.com/docs/config-file/config-basic.

Tiếp theo duyệt hook (bước này làm theo tài liệu Codex; bộ khung chưa thử màn này trên Windows, nên sau đó hãy kiểm như đoạn dưới). Hook là một đoạn script Codex chạy trước mỗi lệnh để kiểm lệnh đó có nguy hiểm không. Vì hook là code chạy trên máy bạn, Codex bắt bạn xem và duyệt nó một lần, và hỏi lại nếu file hook thay đổi. Trong terminal của VS Code (menu **Terminal** > **New Terminal**), gõ `codex`, rồi gõ `/hooks`. Bạn sẽ thấy hook gọi `.codex/hooks/guard.mjs`; chọn trust. Nguồn: https://learn.chatgpt.com/docs/hooks.

Kiểm lớp chặn đang chạy: khi dự án chưa có file `.env`, nhắn agent "chạy lệnh `cat .env`". Nếu agent báo bị chặn bởi `.codex/hooks/guard.mjs` là hook đang hoạt động. Lệnh này vô hại vì lúc đó chưa có file `.env`.

Câu đầu tiên và cách trả lời agent

Câu đầu tiên chỉ cần kể ý tưởng bằng lời thường, ví dụ: "Mình muốn làm app ghi chi tiêu cá nhân." Không cần nói công nghệ. Agent sẽ hỏi lại tối đa năm câu, mỗi câu có lựa chọn đánh chữ. Đây là trả lời đầu tiên thật của Codex khi bộ khung được thử ngày 04/11/2026:

> Bạn chọn giúp mình 5 ý sau, có thể trả lời ngắn như "1a, 2a, 3b, 4b, 5a":
>
> 1. **Ai dùng app?** (a) chỉ bạn, dùng cá nhân (b) gia đình, vài người (c) nhiều người, có thể thu tiền (d) khác
> 2. **Có cần đăng nhập không?** (a) không, lưu trên một trình duyệt (b) email và mật khẩu, dùng được nhiều máy (c) tài khoản Google (d) khác
> 3. **Mỗi khoản chi cần ghi gì?** (a) số tiền và ghi chú (b) thêm danh mục và ngày (c) thêm cả ảnh hoá đơn (d) khác
> 4. **Bạn muốn xem lại thế nào?** (a) danh sách khoản chi (b) danh sách và tổng theo tháng (c) thêm biểu đồ theo danh mục (d) khác
> 5. **Bạn dùng chủ yếu ở đâu?** (a) điện thoại (b) máy tính (c) cả hai (d) khác

Bạn trả lời ngắn như "1a, 2b, 3b, 4b, 5a". Muốn khác gợi ý thì viết thêm, ví dụ "3: thêm cả ảnh hoá đơn, nhưng ảnh nhỏ thôi". Agent ghi câu trả lời vào `docs/brief.md`, rồi đề xuất giải pháp: app có những phần nào, dùng dịch vụ gì, chi phí bao nhiêu, rủi ro gì, và hỏi "Bạn đồng ý hướng này không?". Trong lần thử, agent đề xuất React + Supabase + Cloudflare Pages, chi phí ban đầu 0 USD/tháng, và chưa tạo một file code nào trước khi được đồng ý.

Đọc kỹ đề xuất. Đây là lúc rẻ nhất để đổi ý. Bạn có thể hỏi lại "vì sao chọn cái này", "nếu sau này có 1.000 người dùng thì tốn bao nhiêu", hay "bỏ đăng nhập cho đơn giản". Khi đồng ý, nói rõ "Mình đồng ý". Agent ghi vào `docs/decisions.md`, lập kế hoạch các mốc trong `docs/plan.md`, cho bạn xem rồi mới bắt tay làm mốc 1.

Mỗi mốc diễn ra thế nào

Với mỗi mốc, agent viết code, tự chạy kiểm (thường là `npm run build`), lưu một commit vào git, rồi báo theo mẫu: đã làm gì, bạn mở đâu để tự kiểm, còn gì chưa làm. Ví dụ mốc 1 thường là "khung app chạy ở http://localhost:5173": bạn mở terminal trong thư mục `app`, chạy `npm run dev`, mở link trong trình duyệt và thấy trang trống có tên app.

Hãy thật sự mở ra kiểm sau mỗi mốc. Agent có thể báo "xong" trong khi nút bấm không chạy; bạn phát hiện sớm thì sửa rẻ. Thấy sai thì mô tả bằng lời thường: "bấm Lưu không thấy khoản chi hiện trong danh sách". Kèm ảnh chụp màn hình nếu được.

Phiên làm việc hôm sau, agent đọc `docs/progress.md` trước và tóm tắt "lần trước làm tới đâu". Bạn không cần kể lại từ đầu.

Quyền của agent: khi nào phải dừng đọc kỹ

Codex có hai lớp kiểm soát. **Sandbox** (hộp cát) giới hạn agent được đọc ghi file nào và có dùng mạng không. **Approval** (duyệt) quyết định khi nào agent phải hỏi bạn trước khi làm. Bộ khung đặt sẵn: agent chỉ ghi file trong thư mục dự án, các thư mục `.git` và `.codex` thì chỉ đọc, và phải hỏi bạn trước khi dùng mạng hay làm gì ra ngoài thư mục dự án. Riêng `git add` và `git commit` được cho phép sẵn để agent lưu từng mốc mà không phải hỏi; `git push` vẫn hỏi. Nguồn: https://learn.chatgpt.com/docs/agent-approvals-security.

Trong app và extension, dưới ô nhập có nút chọn chế độ quyền. Tài liệu Codex khuyên bắt đầu với **Ask for approval** (hỏi trước khi vượt ranh giới). Có chế độ **Approve for me**, nơi một hệ thống tự động

xem xét thay bạn; ranh giới sandbox vẫn giữ nguyên. Đừng chọn **Full access**: agent không còn bị giới hạn trong thư mục dự án và có thể vô tình xoá dữ liệu. Nguồn: https://learn.chatgpt.com/docs/permission-modes.

Khi Codex hiện hộp hỏi duyệt, đọc ba thứ: lệnh gì, chạy ở thư mục nào, có cần mạng không. Phần lớn yêu cầu là bình thường, ví dụ `npm install` cần mạng để tải thư viện, bấm đồng ý được. Dừng lại đọc kỹ, và hỏi agent "lệnh này làm gì, có làm mất gì không" khi thấy:

- **Tốn tiền**: nâng gói, gắn thẻ, bật dịch vụ trả phí.
- **Có thể mất dữ liệu**: xoá thư mục không phải `node_modules`, `dist`, `build`; `DROP`, `TRUNCATE`, `DELETE`; `reset`; bất cứ thứ gì có chữ `--force`.
- **Đưa ra công khai**: `git push` (với Cloudflare Pages, push lên nhánh chính là deploy), đổi repo sang public, gửi email thật.
- **Đụng tới tài khoản và key**: agent nhờ bạn tạo tài khoản, lấy key. Tự dán key vào file `.env`, không dán vào cuộc trò chuyện.
- **Ra ngoài thư mục dự án**: đường dẫn bắt đầu bằng `C:\`, `~`, hay `..`.

Trong mấy trường hợp này, bộ luật đã dặn agent tự dừng hỏi bạn. Hộp duyệt là lớp thứ hai, và bạn là lớp cuối.

Giới hạn miễn phí và mốc trả tiền

Bảng dưới ghi giới hạn gói miễn phí và giá gói trả tiền đầu tiên, kiểm ngày 04/11/2026. Mỗi dòng có nguồn ở cột cuối.

Dịch vụ	Miễn phí tới đâu	Mốc trả tiền	Nguồn
Supabase Free	DB 500 MB; storage 1 GB; file tối đa 50 MB; 50.000 người dùng hoạt động/tháng; egress 5 GB; Edge Functions 500.000 lần; 2 project đang chạy. **Tự tạm dừng sau 1 tuần không hoạt động, không có backup.**	Pro từ $25/tháng (đã gồm $10 credit tính toán)	supabase.com/pricing
Cloudflare Pages	500 lần build/tháng; file tĩnh miễn phí	Workers Paid từ $5/tháng khi cần chạy code phía server nhiều	developers.cloudflare.com/pages/platform/limits
Cloudflare Workers Free	100.000 request/ngày, 10 ms CPU mỗi lần	Workers Paid từ $5/tháng	developers.cloudflare.com/workers/platform/pricing
Cloudflare R2	10 GB-tháng; 1 triệu thao tác ghi (Class A), 10 triệu thao tác đọc (Class B); egress $0	$0,015/GB-tháng phần vượt. Phải bật gói R2 qua bước thanh toán	developers.cloudflare.com/r2/pricing
Vercel Hobby	100 GB truyền tải/tháng. Chỉ cho dùng cá nhân, phi thương mại	Pro $20/tháng	vercel.com/pricing
Resend Free	3.000 email/tháng, 100 email/ngày	Pro $20/tháng	resend.com/pricing
Google Drive	Tài khoản mới 5 GB, thêm 10 GB khi xác minh số điện thoại (tài khoản tạo từ 09/03/2026)	Google One	support.google.com/drive/answer/2375123

Dịch vụ	Miễn phí tới đâu	Mốc trả tiền	Nguồn
Codex (ChatGPT)	Free/Go: model nhỏ trong app máy tính	Plus $20/tháng; Pro từ $100/tháng	learn.chatgpt.com/docs/pricing
Claude Code	Không có trong gói Free	Pro $20/tháng	claude.com/pricing

Vài điều đáng nhớ từ bảng này:

- **Vercel Hobby không dùng cho app có thu tiền.** Trang giá ghi gói Hobby dành cho mục đích cá nhân, phi thương mại. Vì vậy bộ khung chọn Cloudflare Pages làm mặc định; gói free của Cloudflare không có điều kiện đó.
- **Supabase Free tự tạm dừng** nếu một tuần không có hoạt động. App vẫn còn, chỉ là đang "ngủ"; xem cách mở lại ở chương cuối. Và **gói Free không có backup**: lỡ xoá là mất, nên bộ khung có script sao lưu.
- **R2** chỉ cần khi tổng file vượt khoảng 1 GB (mức storage của Supabase Free). Theo tài liệu Cloudflare, muốn dùng R2 phải bật gói R2 qua bước thanh toán; diễn đàn Cloudflare cho biết bước này đòi phương thức thanh toán dù dùng trong mức free. Bạn sẽ bị tính tiền nếu vượt mức.
- **Google Drive** chỉ hợp khi app lưu file vào Drive của chính người dùng (mỗi người tự lưu vào Drive của họ), xin quyền hẹp `drive.file`: app chỉ thấy file nó tạo hoặc người dùng chọn. Quyền này Google xếp loại "không nhạy cảm", xét duyệt nhẹ. Quyền rộng `drive` (thấy mọi file) thuộc loại hạn chế, xét duyệt nặng. Đừng dùng Drive làm kho chứa chính của app. Nguồn: https://developers.google.com/workspace/drive/api/guides/api-specific-auth.

Hai sự cố có thật và cách bộ khung chặn

Lovable và RLS bị thiếu (2025)

Lovable là một công cụ tạo app bằng AI, dùng Supabase làm database. Đầu năm 2025, nhà nghiên cứu Matt Palmer quét các app được giới thiệu trên trang Lovable Launched. Theo bài công bố của ông, trong 1.645 app được quét có 170 project (khoảng 10,3%) với 303 điểm truy cập để lộ dữ liệu vì thiếu hoặc sai RLS. Dữ liệu lộ gồm tên, số điện thoại, email, thông tin thanh toán, API key của dịch vụ khác. Ở một app, người quét còn ghi được dữ liệu: chèn một bản ghi "đã thanh toán" để bỏ qua bước trả tiền. Lỗi được đăng ký mã CVE-2025-48757 ngày 29/05/2025. Nguồn: https://mattpalmer.io/posts/statement-on-CVE-2025-48757/.

Vì sao chuyện này xảy ra: app gọi Supabase thẳng từ trình duyệt bằng "publishable key" (còn gọi anon key). Key này công khai theo thiết kế, ai mở trang cũng thấy. Thứ bảo vệ dữ liệu là **RLS** (Row Level Security, luật ai được đọc dòng nào trong bảng). Bảng không bật RLS, hay bật mà luật quá rộng, thì bất kỳ ai cầm key công khai đó cũng đọc được cả bảng. Nguồn: https://supabase.com/docs/guides/database/postgres/row-level-security.

Bộ khung chặn bằng cách: luật bắt agent bật RLS cho mọi bảng ngay khi tạo, thu hết quyền mặc định rồi cấp lại đúng chỗ; skill `security-check` có câu SQL tìm bảng chưa bật RLS và liệt kê quyền, policy; bắt thử bằng hai tài khoản (A không thấy dữ liệu B) trước khi deploy; hook chặn lệnh tắt RLS. Agent cũng không được đặt secret key (`service_role`) trong code giao diện.

Replit xoá database thật (07/2025)

Tháng 7/2025, Jason Lemkin, nhà sáng lập cộng đồng SaaStr, kể rằng agent AI của Replit đã xoá database production (dữ liệu thật) trong lúc ông đang yêu cầu "đóng băng" code, bỏ qua chỉ dẫn, và còn tạo dữ liệu giả. CEO Replit gọi sự việc là "không thể chấp nhận". Theo blog của Replit được The Register trích, trước đó app trên Replit dùng chung một database cho cả phát triển lẫn dữ liệu khách hàng thật, và sau sự cố Replit bắt đầu tách database dev và prod tự động. Nguồn: https://www.theregister.com/2025/07/22/replit_saastr_response/.

Bài học: agent có thể làm sai dù đã được dặn. Thứ duy nhất chắc chắn là agent **không có cách chạm** vào dữ liệu thật. Bộ khung chặn theo nhiều lớp:

- **Hai project Supabase**: dev cho agent làm việc, prod cho người dùng thật. Agent chỉ được link với dev. Mật khẩu database prod không nằm trong repo hay file `.env` của máy làm việc. Đưa thay đổi lên prod là việc bạn tự làm theo hướng dẫn của skill deploy, sau khi đã thử trên dev.
- **MCP Supabase** (cách cho agent đọc database trực tiếp), nếu dùng, chỉ trỏ vào dev, có `read_only=true` và `project_ref` cố định. Nguồn: https://supabase.com/docs/guides/getting-started/mcp.
- **Hook và rules** chặn `DROP`, `TRUNCATE`, `DELETE` không `WHERE`, `supabase db reset --linked`, xoá project hay bucket trên cloud, và các lệnh git xoá lịch sử. Khi thử ngày 04/11/2026 (trên macOS, chưa thử trên Windows), yêu cầu Codex chạy `rm -rf scripts` và `git reset --hard` đều bị chặn, file còn nguyên.
- **Sao lưu**: script `scripts/backup-supabase.mjs`, agent nhắc bạn chạy sau mỗi thay đổi cấu trúc database và hằng tuần.

Lớp chặn lệnh đọc chữ của lệnh, nên không bắt được mọi cách viết (ví dụ một script tự xoá file). Đó là lưới an toàn chống nhầm, không phải hàng rào tuyệt đối. Lớp quan trọng nhất vẫn là: không đưa mật khẩu prod cho agent.

Sự cố hay gặp và cách gỡ

Supabase báo project bị tạm dừng

Gói Free tự tạm dừng project sau một tuần không hoạt động. App sẽ báo lỗi kết nối. Vào https://supabase.com/dashboard, chọn project, bấm nút khôi phục (restore) trên trang project và chờ vài phút. Project dev hay bị dừng nhất vì bạn không đụng tới nó khi nghỉ vài ngày; đó là bình thường. Nếu project prod có người dùng thật mà vẫn bị dừng thường xuyên, đã tới lúc cân nhắc gói Pro.

Hết hạn mức Codex

Codex tính hạn mức theo khung 5 giờ và theo tuần, xem ở trang usage của tài khoản. Hết hạn mức giữa chừng thì lượt đang chạy vẫn được làm nốt. Sau đó bạn chờ tới giờ reset, mua thêm credit, hoặc mở cùng dự án bằng Claude Code (bộ khung chạy được với cả hai). Để tiết kiệm: mỗi lượt giao một việc rõ ràng ("làm mốc 3 trong plan"), mở phiên mới khi đổi sang việc khác hẳn, và đừng dán nguyên file log dài nếu chỉ cần đoạn lỗi.

Lỗi build

Lỗi khi chạy `npm run build` trên máy: chép đoạn lỗi (vài dòng có chữ `error`) gửi agent và nói "build lỗi thế này". Lỗi khi Cloudflare Pages build: vào Cloudflare > dự án > **Deployments** > bản lỗi > **View build log**, chép đoạn lỗi cho agent. Lỗi chỉ xảy ra trên Cloudflare mà máy bạn build được thường do thiếu biến môi trường (`VITE_SUPABASE_URL`...) trong cài đặt của dự án trên Cloudflare, hoặc sai **Root directory** (phải là `app`). Web đang chạy bị hỏng sau một lần deploy: trong **Deployments** chọn bản cũ còn tốt và bấm **Rollback**.

Agent đi lạc, muốn quay lại bản trước

Vì mỗi mốc là một commit, bạn luôn có điểm để quay về. Trong VS Code, mở mục **Source Control** (biểu tượng nhánh cây) để xem file nào vừa đổi. Cách an toàn:

- **Chưa commit, muốn bỏ thay đổi của một file**: trong Source Control, chuột phải file đó > **Discard Changes**. Chỉ làm khi chắc không cần thay đổi đó.
- **Đã commit, muốn huỷ một commit**: nhờ agent "huỷ commit mốc 4 bằng git revert". `git revert` tạo commit mới đảo ngược commit cũ, lịch sử vẫn còn đủ.
- **Muốn thử lại từ một mốc cũ**: nhờ agent "tạo nhánh mới từ commit mốc 2". Bản hiện tại vẫn nằm nguyên ở nhánh cũ.

Tránh `git reset --hard` và `git push --force`: chúng xoá thay đổi hay lịch sử và không lấy lại được. Bộ khung chặn agent chạy hai lệnh này; nếu thật sự cần, bạn tự chạy sau khi hiểu nó làm gì.

Sao lưu và thử phục hồi database

Cài Docker Desktop và mở nó (Supabase CLI chạy công cụ sao lưu trong Docker). Lấy chuỗi kết nối của project dev ở Supabase > nút **Connect** > **Session pooler**, điền vào dòng `SUPABASE_DEV_DB_URL` trong `.env` (mật khẩu có ký tự đặc biệt thì mã hoá, ví dụ `@` thành `%40`). Rồi chạy trong thư mục dự án:

```
node scripts/backup-supabase.mjs --dry-run
node scripts/backup-supabase.mjs
```

Lệnh đầu chỉ in ra lệnh sẽ chạy, mật khẩu được che. Lệnh sau tạo thư mục `backups/<ngày_giờ>-dev/` gồm ba file: vai trò, cấu trúc, dữ liệu. Chép thư mục đó ra ổ ngoài hay Drive cá nhân; nó không bao giờ lên git. Sao lưu không gồm file trong Supabase Storage, chỉ gồm dòng mô tả file. Với prod, bạn tự chạy với `--prod`, và đặt chuỗi kết nối prod chỉ trong cửa sổ PowerShell đó (hướng dẫn trong `.agents/skills/backup-supabase/SKILL.md`). Ít nhất một lần, thử phục hồi bản sao lưu vào một project dev trống theo hướng dẫn chính thức để chắc nó dùng được: https://supabase.com/docs/guides/platform/migrating-within-supabase/backup-restore. Script đã được thử ở chế độ `--dry-run` trên macOS; lần chạy thật đầu tiên trên Windows hãy xem kỹ thông báo.

Lỡ để lộ key

Lỡ dán key vào cuộc trò chuyện, commit file `.env`, hay đẩy secret lên GitHub: coi như key đã mất. Vào dashboard của dịch vụ (Supabase > Project Settings > API keys, hay trang key của dịch vụ đó), tạo key mới và vô hiệu key cũ, rồi cập nhật `.env` và biến môi trường trên Cloudflare. Xoá file khỏi git không đủ, vì lịch sử git vẫn giữ bản cũ.

Thuật ngữ

Từ	Nghĩa ngắn
Agent	Trợ lý AI tự đọc file, chạy lệnh, viết code (Codex, Claude Code)
`AGENTS.md`	File luật agent đọc đầu mỗi phiên
Commit	Một lần lưu thay đổi vào lịch sử git, có thể quay lại
Push	Đẩy các commit lên GitHub
Deploy	Đưa app lên mạng để người khác mở được
Dev / prod	Bản để làm và thử / bản thật có người dùng
RLS	Luật ai được đọc, sửa dòng nào trong bảng database
Publishable key	Key công khai cho giao diện gọi Supabase; chỉ an toàn khi RLS đúng
Secret / `service_role` key	Key toàn quyền; không bao giờ đặt trong code giao diện
`.env`	File chứa key trên máy bạn, không lên git
Hook	Script chạy trước mỗi lệnh của agent để chặn lệnh nguy hiểm
MCP	Cách nối agent với dịch vụ ngoài (database, Cloudflare…)
Sandbox	Ranh giới file và mạng agent được phép dùng

Nguồn

Kiểm ngày 04/11/2026.

- Codex: giá https://learn.chatgpt.com/docs/pricing; Windows https://learn.chatgpt.com/docs/windows/windows-app, https://learn.chatgpt.com/docs/windows/windows-sandbox; quyền https://learn.chatgpt.com/docs/permission-modes; cấu hình https://learn.chatgpt.com/docs/config-file/config-basic; hooks https://learn.chatgpt.com/docs/hooks; rules https://learn.chatgpt.com/docs/agent-configuration/rules; AGENTS.md https://learn.chatgpt.com/docs/agent-configuration/agents-md; CLI https://github.com/openai/codex.
- Claude: giá https://claude.com/pricing; cài đặt https://code.claude.com/docs/en/setup; bộ nhớ và `AGENTS.md` https://code.claude.com/docs/en/memory.
- Supabase: giá https://supabase.com/pricing; RLS https://supabase.com/docs/guides/database/postgres/row-level-security; MCP https://supabase.com/docs/guides/getting-started/mcp; sao lưu https://supabase.com/docs/guides/platform/migrating-within-supabase/backup-restore.
- Cloudflare: Pages https://developers.cloudflare.com/pages/platform/limits/; Workers https://developers.cloudflare.com/workers/platform/pricing/; R2 https://developers.cloudflare.com/r2/pricing/, https://developers.cloudflare.com/r2/get-started/.

- Vercel: https://vercel.com/pricing, https://vercel.com/docs/plans/hobby. Resend: https://resend.com/pricing.
- Google Drive: https://developers.google.com/workspace/drive/api/guides/api-specific-auth, https://support.google.com/drive/answer/2375123.
- Sự cố: Lovable https://mattpalmer.io/posts/statement-on-CVE-2025-48757/; Replit https://www.theregister.com/2025/07/22/replit_saastr_response/.